

Azure Key Vault: Architecture, Planes, and Security

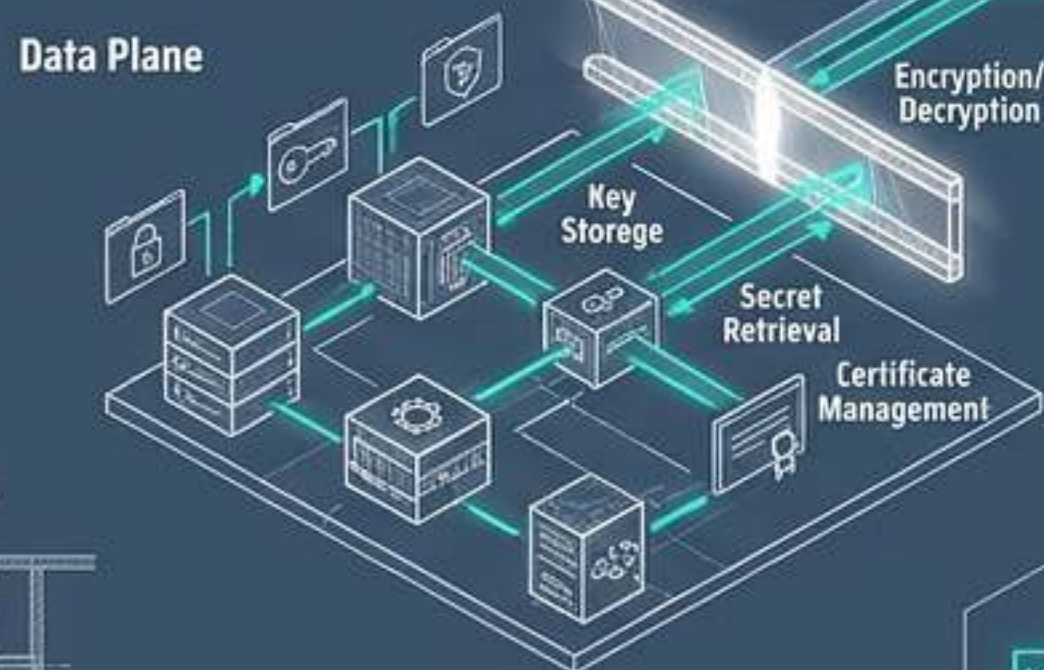
Building the Zero-Trust Digital Fortress

ARCHITECTURE & PLANES

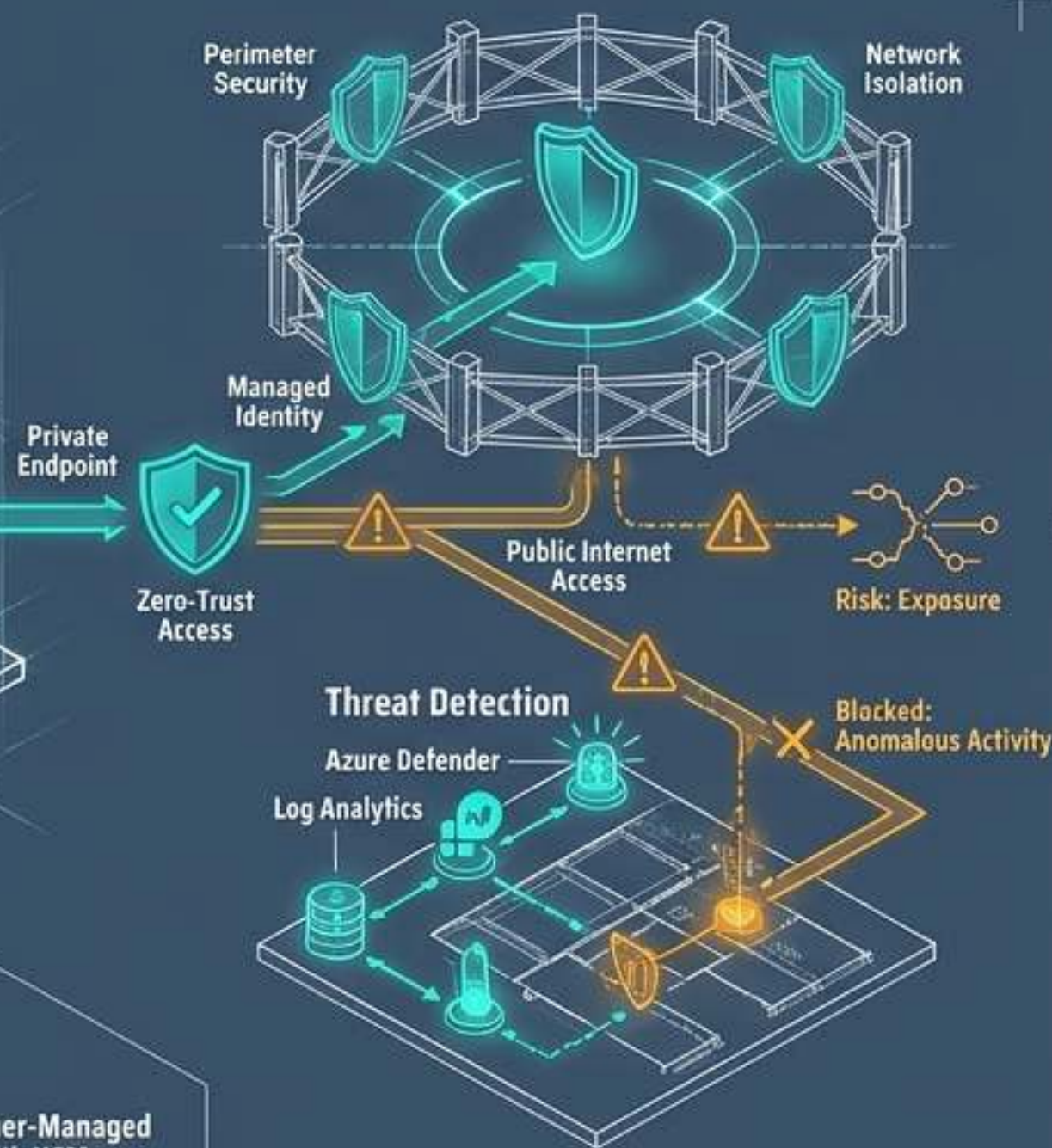
Management Plane



Data Plane



SECURITY & THREAT MITIGATION



RECOMMENDED CONFIGURATIONS

- ✓ **Enable Soft Delete & Purge Protection**
Enable Soft Delete & Purge Protection, now secure your secrets in the vaults and storage automation.
- ✓ **Implement Role-Based Access Control (RBAC)**
Implement role-based access control (RBAC) to manage data access on premises.
- ✓ **Utilize Customer-Managed Keys (CMK) with HSM**
Utilize Customer-Managed Keys (CMK) with HSM to manage the anomalous security.

THE FOUNDATION: HARDWARE & DURABILITY

Building a Secure Digital Fortress

HARDWARE / SKU OPTIONS



Standard Tier

Software-protected keys. Complies with FIPS 140-2 Level 1.



Premium Tier

Hardware Security Module (HSM) backed. Complies with FIPS 140-2 Level 2.

Private key material is generated inside the HSM and never leaves in plaintext.



DURABILITY SETTINGS



Soft Delete

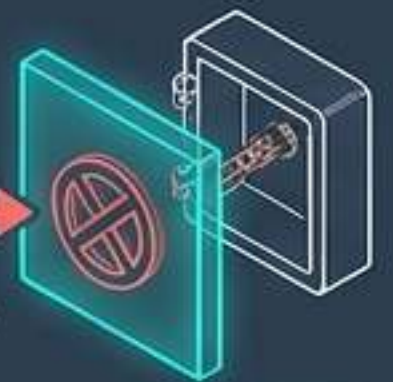
Always-on retention window (7 to 90 days) for accidental object deletions.



Purge Protection

Off by default. Irreversible once enabled. Blocks even subscription Owners from bypassing the soft-delete window. Required for integrating with services using Customer-Managed Keys (CMK).

Subscription Owner



Required for CMK Integration



THE TWO DOORS: ARCHITECTURE & ACCESS PLANES

Building a Secure Digital Fortress

Top Floor: Control Plane

- **Route:** Azure Resource Manager (ARM) REST APIs
- **Actions:** Create/delete the vault, change network rules, view metadata.
- **Users:** Platform and DevOps Engineers managing infrastructure.

Bottom Floor: Data Plane

- **Route:** Key Vault REST APIs
- **Actions:** Read a secret, use a cryptographic key, retrieve a certificate.
- **Users:** Applications, Managed Identities, AI Agents.

Authorization Air Gap

Authorization is strictly independent. A role granted on the Control Plane confers absolutely nothing on the Data Plane.

THE EXPLOIT: LEGACY PRIVILEGE ESCALATION

Building a Secure Digital Fortress

1. Top Floor Access

A user holds a standing Contributor role on the Control Plane, intended only for infrastructure management.

3. Bottom Floor Infiltration

They grant themselves full Key Vault Administrator privileges on the Data Plane.

2. The Breach

Because the vault relies on Legacy Access Policies, this user maliciously edits the policy configuration.

4. The Theft

They successfully extract a sensitive database secret, bypassing all intended data-plane controls.



CRITICAL RISK: Standing access combined with the legacy policy model creates a trivial privilege escalation loop. Contributor rights allow the self-granting of data access.

THE AUTHORIZATION MATRIX: CLOSING THE GAP

Building a Secure Digital Fortress

	LEGACY ACCESS POLICIES
Architecture	Vault-specific custom authorization engine.
Privilege Escalation Risk	HIGH. Control Plane Contributors can self-grant Data Plane access.
Granularity	Broad, often resulting in overly permissive assignments.
PIM (Just-in-Time) Compatibility	No. Access is always standing and permanent.

AZURE RBAC
Tenant-wide Azure Resource Manager integration.
NONE. Requires explicit roleAssignments/write permission to modify access.
Fine-grained, purpose-built data plane roles.
Yes. Fully supports time-boxed, MFA-verified elevation.



OD	Owner	ROK	SMC	PDATCONTGSS	TManpetal		
					Prepot Tirt		
					Title	References	Code
						0027008-0001	

THE BOUNCERS: DATA PLANE ROLES REFERENCE

Building a Secure Digital Fortress



THE MOAT: NETWORK ISOLATION OPTIONS

Building a Secure Digital Fortress

IP FIREWALL RULES

Internet Reachable?: Yes.

Traffic Path:
Public Internet (filtered by
CIDR block).

Best For:
Transitional architectures or
static CI/CD agent pools.

VNET SERVICE ENDPOINTS

Internet Reachable?: Yes
(Public DNS resolution remains).

Traffic Path:
Azure Backbone (optimized
routing).

Best For:
Workloads in VNets where full
private DNS is architecturally
prohibitive.

PRIVATE ENDPOINTS

Internet Reachable?: No
(Public access explicitly disabled).

Traffic Path:
Private Link (Secured within
Azure Backbone).

Best For:
Production workloads, sensitive
data, and true Zero-Trust
architectures.



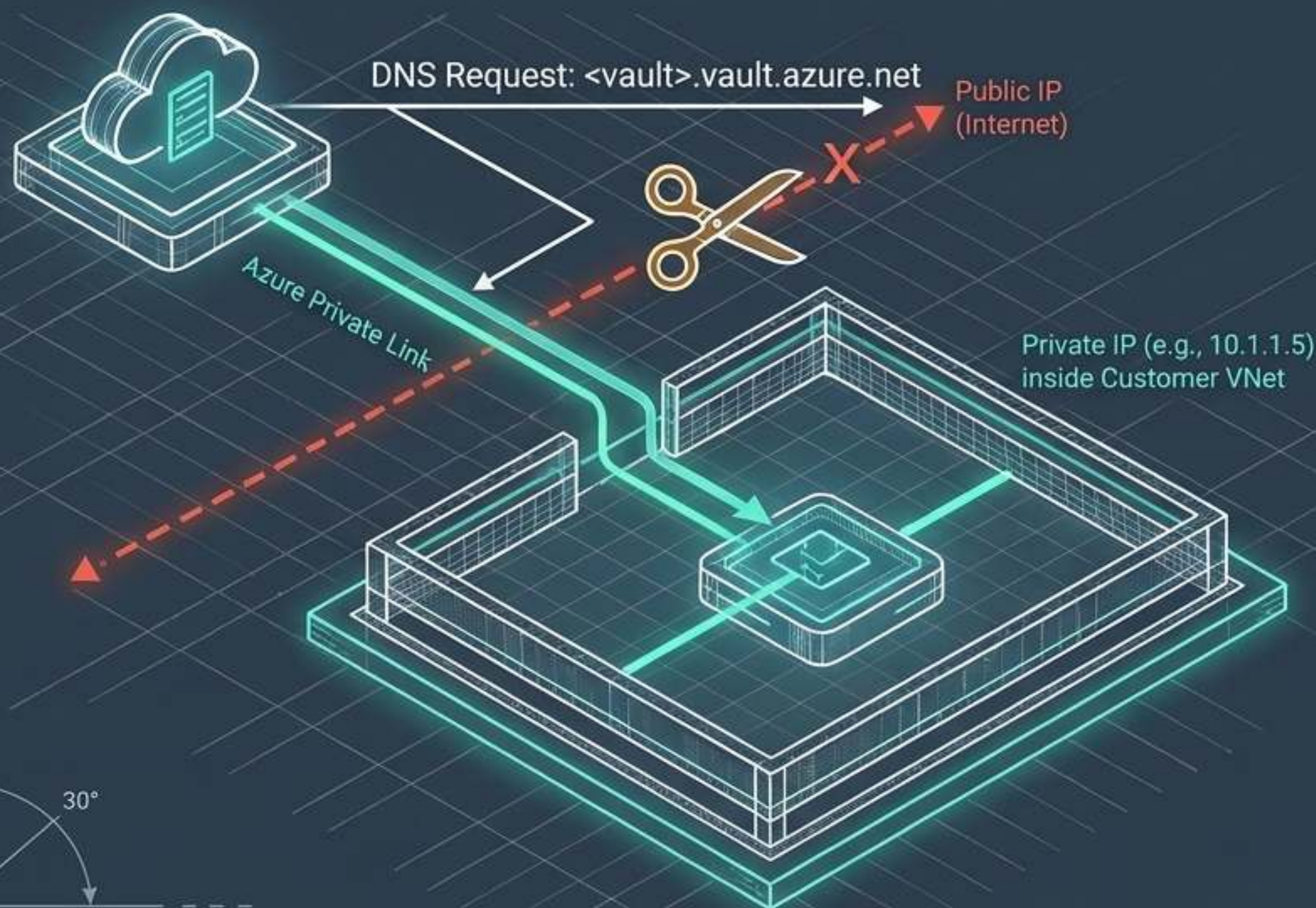
Project Title: Building a Secure Digital Fortress

Reference: 003/009-0002

Revision: 1.0

THE REROUTE: HOW PRIVATE ENDPOINTS WORK

Building a Secure Digital Fortress



The Mechanism

- Requires a Private Endpoint Network Interface (NIC) deployed directly into the VNet subnet.
- Requires a Private DNS Zone (`privatelink.vaultcore.azure.net`) linked to the VNet to rewrite the DNS resolution to the new private IP.

Critical Security Settings

- **Public Network Access:** Set to Disabled to drop all non-VNet traffic at the perimeter.
- **Trusted Services Bypass:** Allows native Azure services (e.g., Azure Backup) to connect, overriding the block.

THE ASSETS: DECONSTRUCTING CERTIFICATES

Building a Secure Digital Fortress



[Certificate Icon]

=



[Cryptographic Key Icon]

+



[Retrievable Secret Icon]



Cryptographic Keys

RSA or Elliptic Curve pairs used for signing and encrypting. The private material performs operations strictly inside the vault boundary.

ENCRYPTING

Secrets

Opaque string values and tokens. Stored securely and retrieved entirely by authorized applications at runtime.



The Exportability Tradeoff

A Key Vault Certificate automatically provisions a paired Key (for operations) and Secret (for retrieving the PFX).

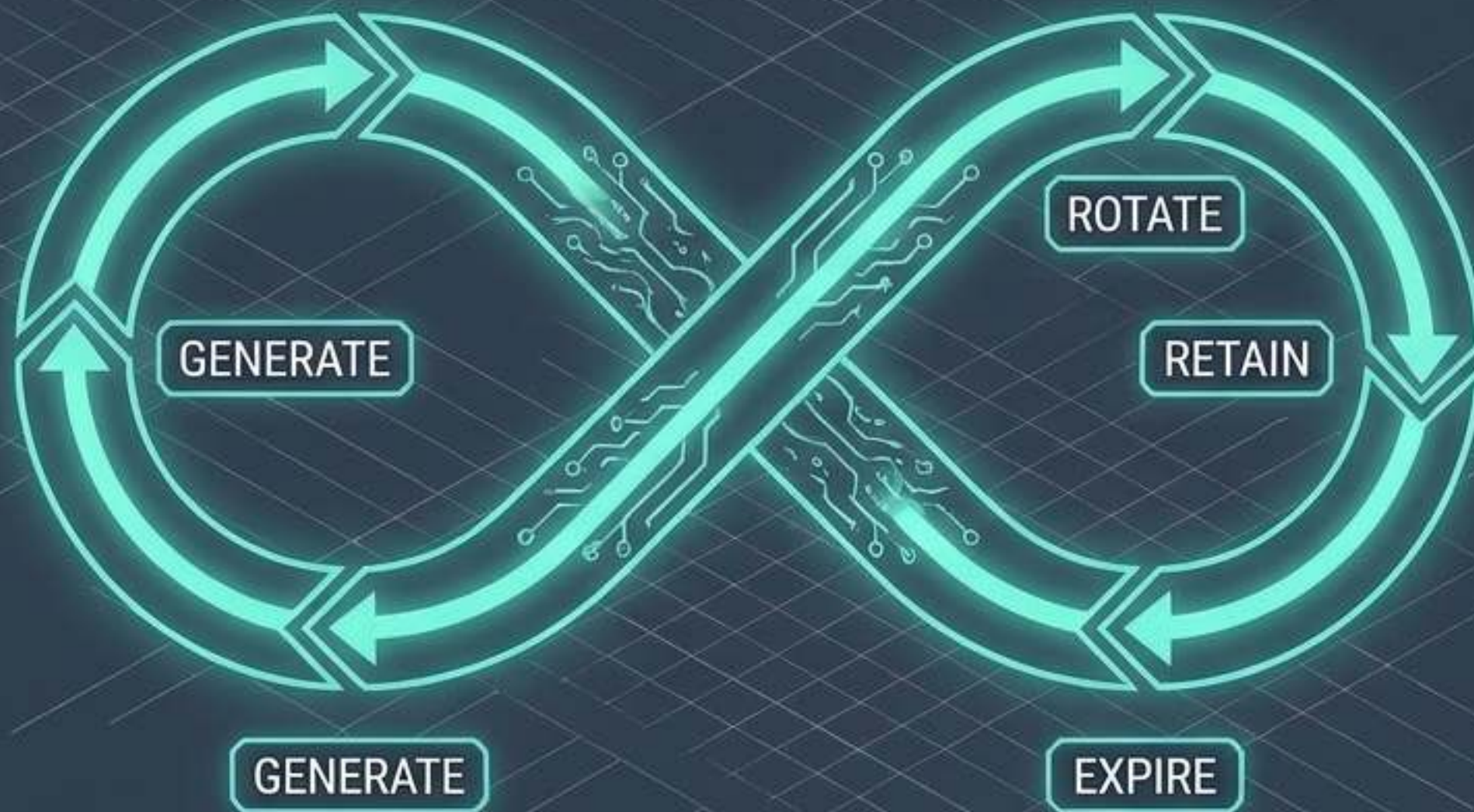
Non-exportable certificates keep the private key permanently inside the vault.

Exportable certificates allow the private key to be downloaded by workloads, but this removes Key Vault's protective boundary.

Architectural scale

THE LIFECYCLE: PREVENTING CREDENTIAL STALENESS

Building a Secure Digital Fortress



AUTOMATED KEY ROTATION

Policies automatically define a rotation interval (e.g., 18 months). Old versions are retained, not deleted, ensuring historically encrypted data remains completely decryptable.

ZERO-DOWNTIME SECRET ROTATION

Versionless URIs: Applications point to the base URI without a specific version ID. Upon rotation, the application automatically fetches the newly generated value within 24 hours or upon restart.

Dual-Credential Pattern: For databases, rotate the Secondary key -> swap application traffic to Secondary -> rotate the Primary key. The application is never left without a valid credential during the transition.

THE SURVEILLANCE: CONTINUOUS POSTURE & THREAT DETECTION

Building a Secure Digital Fortress

THE OUTSIDE SWEEP: DEFENDER CSPM

AGENTLESS POSTURE MANAGEMENT

WHAT IT DOES: Hunts for static secrets that have escaped the vault.

TARGETS: Connection strings left in VM disks, source code repositories, and IaC templates.

ACTION: Validates if leaked SSH or API keys permit lateral movement.

OUTSIDE THE VAULT

INSIDE THE VAULT

THE INSIDE SWEEP: DEFENDER FOR KEY VAULT

CLOUD WORKLOAD PROTECTION (CWPP)

WHAT IT DOES: Watches live runtime access patterns for compromised identities.

TARGETS: Access from TOR exit nodes, abnormal volume or burst harvesting, and unfamiliar AI agent behavior.

ACTION: Flags technically valid credentials that are exhibiting malicious behavioral patterns.

30°

Architectural scale

THE CAMERAS: DIAGNOSTIC AUDIT LOGGING

Building a Secure Digital Fortress

WARNING: Diagnostic Logging is **OFF** by default. It must be explicitly enabled to conduct incident response.

VITAL LOG FIELDS FOR INVESTIGATION

- **operationName:** Identifies exactly what happened (e.g., SecretGet, KeyCreate).
- **callerIpAddress:** The source network of the request. Crucial for spotting stolen tokens being used off-network.
- **identity:** The Object ID and UPN of the caller executing the operation.
- Captures both Control Plane (ARM) and Data Plane (REST API) activity.

INCIDENT RESPONSE FLOW

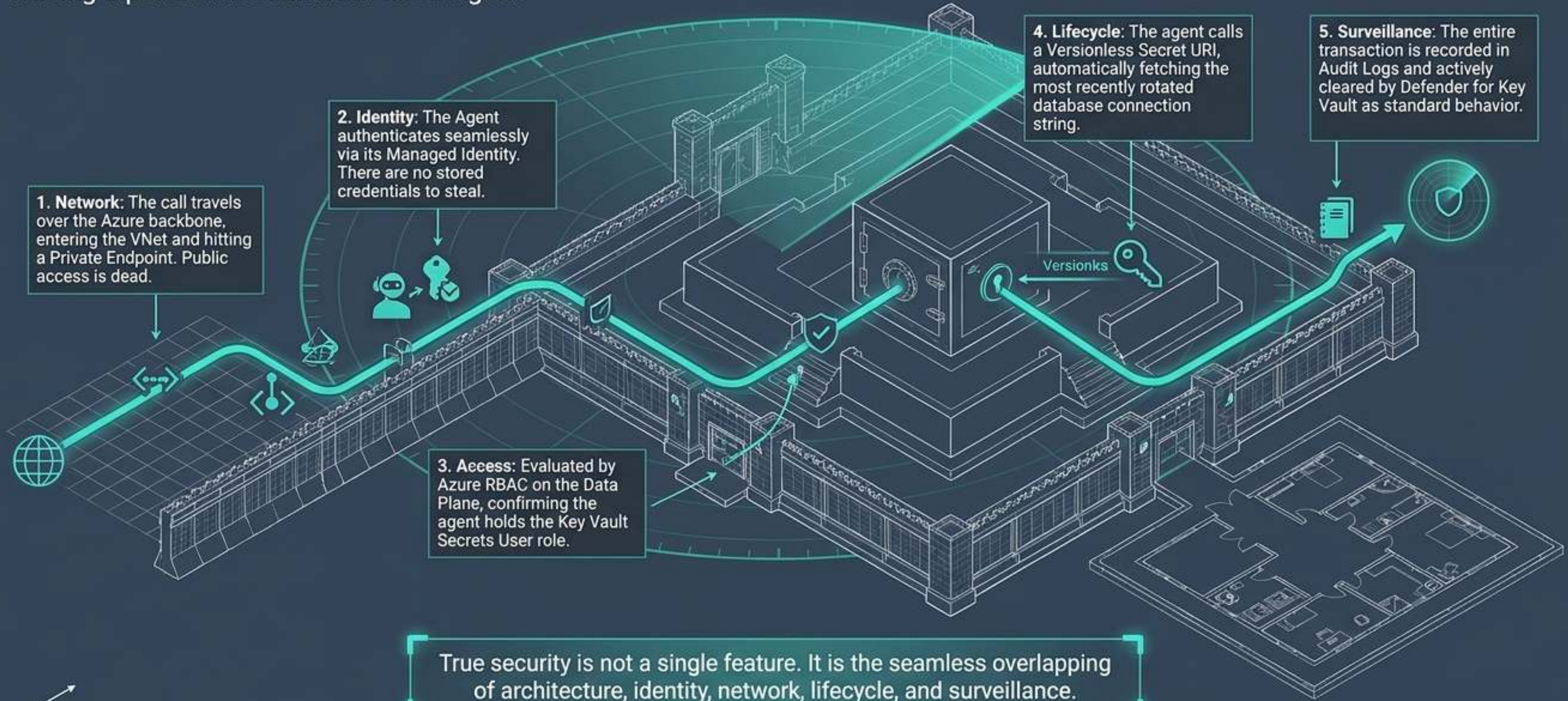
1. **Identify:** Pinpoint the anomalous source IP or identity.
2. **Contain:** Block the IP at the firewall or revoke the RBAC role.
3. **Scope:** Query the AuditEvent table for the past 72 hours of activity.
4. **Remediate:** Rotate all exposed secrets touched by the compromised identity.

Architectural scale



SYNTHESIS: THE ZERO-TRUST SECURE REQUEST FLOW

Tracing a perfect API call from an AI Agent:



30°

Architectural scale